

STEADY PLATFORM

Platform Readiness Review and ADR 0010 Step 5 Execution Plan

A verified assessment of the repository, migration state, security and clinical gaps, founder decisions, and the controlled path to event-authoritative writes.

Prepared for Travis Rawlings

Repository: tprawlins-lang/Emdr

Repository snapshot: 29a0227, August 27, 2026

Executive decision

Hold ADR 0010 Step 5 today. Target the event-authoritative cutover for September 14 to 18, 2026, after the Postgres, tenant-context, RLS, rollback, and seven-day synthetic staging gates pass. If any gate fails, dual-write stays active while the defect is corrected. BLS Part 6 remains active as a parallel clinical validation workstream.

This document records the verified repository state and the sequence that turns Step 5 from a risky code change into a controlled migration.

1. Executive assessment

Steady has moved beyond a simple prototype. The repository now contains an event spine, a split person and account identity model, tenant columns, a tenant-scoped repository layer, Postgres row-level security policy code, replay verification, and a large automated test suite. That is real progress.

The current status still describes several foundations as though they already govern the running application. They do not. SQLite remains active, RLS remains dormant, application call sites have not moved fully behind TenantContext, and event appends still fail open during dual-write. Those conditions are acceptable for a synthetic investor demonstration. They are not acceptable for event-authoritative writes or real clinical data.

Decision	Recommendation	Reason
ADR 0010 Step 5	HOLD	The event path is not yet fail-closed, fully scoped, or proven on the target Postgres runtime.
Next work	START SECURITY AND CLINICAL DEFINITION	The clinician workflow determines PHI movement, permissions, alerts, exports, and review responsibilities.
Postgres	PREPARE AND REHEARSE	RLS, secrets, restore, migration, and tenant context must work together before real data.
BLS Part 6	KEEP ACTIVE IN PARALLEL	Continue the protocol, evidence, reviewer, and validation work. Member-facing access remains gated until its own clinical and security conditions pass.

What the current build proves

The team can execute difficult migrations while preserving the working prototype. The replay tests found real defects in IDs, consent coverage, session ordering, and timestamp behavior. That is exactly what a migration test should do.

2. Verified repository state

Area	Verified state	Assessment
Branches	main, claude/gifted-keller-501y5d, and claude/launch-status-vh6vbo point to 29a0227	In sync at review time
Unit and safety tests	327 passed, 0 failed	Current head green
Browser tests	17 passed	Current head green
Build	Next.js production build passed	Current head green
Production dependencies	0 production vulnerabilities in the blocking audit	Pass, dev toolchain findings remain separate
Secret scanning	gitleaks workflow passed	Current head green
Projection replay	Six current-state tables rebuild byte-identically in live-path and demo tests	Strong proof within declared scope
RLS attack script	Twelve Postgres attack cases reported as passing	Script exists, but it is not part of the main CI workflow

Diligence wording should say: Current head passes all repository gates. Do not say every commit passed. Two branch runs failed at an intermediate backfill commit before later fixes, while the final head passed across all three synchronized branches.

The README now points readers to the platform strategy, gap analysis, ADRs 0009 through 0012, migration status, reviewer paths, and the open Step 5 decision. It works as an internal map. It still needs a later rewrite before external circulation because the old consumer thesis and the new enterprise clinical thesis appear together.

3. Why Step 5 is not ready today

#	Finding	Current condition	Required closure
1	Projection scope	Only checkins, therapy_sessions, practice_completions, lesson_reads, consents, and module_unlocks rebuild fully. Credentials, encrypted screenings, and encrypted memory remain partial by design.	Define the exact Step 5 table and command scope.
2	Failure behavior	appendEventSafe catches event failures and lets the current-state write succeed.	Replace it with a required append for authoritative commands.
3	Atomicity	The final path must append the event and update projections in one transaction.	A failure must roll back both sides.
4	Tenant call sites	The repository layer enforces TenantContext when used, but the tenancy commit did not migrate product call sites.	Move tenant-scoped reads and writes behind a tenant-aware path.
5	Postgres RLS context	The data layer does not set app.tenant_id inside Postgres transactions.	Add tenant-aware transactions that issue SET LOCAL app.tenant_id.
6	RLS CI	npm run test:rls exists, but safety.yml does not execute it.	Make the Postgres attack suite blocking in CI.
7	Operations	The deployment secret manager, database roles, one-time load, restore proof, and rollback procedure remain open.	Resolve and rehearse before cutover.

The key distinction

The repository contains tenant-safe building blocks and tested RLS policies. The running SQLite application does not yet provide active, end-to-end tenant isolation. Security material must state the difference plainly.

4. Step 5 execution schedule

The schedule below assumes development begins immediately, founder decisions arrive within forty-eight hours, and the synthetic staging environment exposes no material defect. Clinical and security documentation can continue in parallel. Real PHI remains prohibited throughout this period.

Window	Work block	Work	Exit
Aug 27 to Sep 1	Scope and transaction design	List authoritative commands and tables. Define event schemas, atomic projection behavior, retry and idempotency rules, failure policy, and rollback flag.	Approved Step 5 technical specification
Sep 2 to Sep 4	Tenant and RLS plumbing	Add tenant-aware Postgres transactions, migrate the first required call sites, make RLS attacks blocking in CI, and close bypass paths.	Tenant-context tests and RLS CI green
Sep 3 to Sep 5	Infrastructure decision	Select managed Postgres and the matching secret system. Provision non-owner application and administration roles. Define backup and access ownership.	Synthetic staging environment ready
Sep 5 to Sep 7	Migration and rollback rehearsal	Load synthetic SQLite data into Postgres, verify counts and hashes, run replay, tenant attacks, audit-chain verification, backup, restore, and rollback.	Rehearsal signed off
Sep 7 to Sep 14	Seven-day dual-write soak	Run all synthetic investor, web, mobile, clinician-console, scheduled, and error paths. Compare projections every day. Require zero unexplained gaps.	Seven consecutive clean days
Sep 14 to Sep 18	Step 5 cutover	Enable event-authoritative writes for the approved scope behind a reversible flag. Monitor errors, drift, latency, and event counts. Keep real PHI prohibited.	Step 5 complete or rolled back safely
First 72 hours after	Intensive monitoring	Daily full replay verification, error review, database growth check, rollback readiness, and incident owner availability.	Cutover accepted

If the infrastructure choice or tenant transaction design slips, the cutover window moves. The application stays on verified dual-write. We do not compress the seven-day soak to protect a date.

5. Step 5 go or no-go gates

Gate	Name	Pass condition	Owner
G1	Authoritative scope	Every command and table in Step 5 is listed. Partial projections are explicitly excluded or assigned a protected-content strategy.	Architecture owner
G2	Atomic transaction	Event append and projection update commit together. Event failure fails the command.	Engineering
G3	Tenant context	Every in-scope request carries authenticated tenant context through the data transaction.	Engineering and security
G4	RLS enforcement	Application role is non-owner, non-superuser. SET LOCAL app.tenant_id works. The twelve attack cases block CI.	Security
G5	Replay	Full replay produces zero gaps and byte-identical results for every fully projected table.	Engineering
G6	Postgres rehearsal	Synthetic migration, backup, restore, audit-chain verification, and rollback all pass.	Engineering and operations
G7	Soak	Seven consecutive days with zero unexplained divergence across web, mobile, clinician, and scheduled paths.	Engineering
G8	Observability	Alerts exist for append failure, projection failure, replay drift, tenant-context failure, and database saturation.	Engineering and security
G9	Rollback	One documented command or configuration change restores dual-write. The team rehearses it before cutover.	Engineering
G10	Data restriction	Only fabricated data exists in the environment during this cutover. No patient or staff health data.	Founder and compliance

Go or no-go rule

Step 5 executes only when all ten gates show PASS. A partial pass is a no-go. The rollback flag stays available through the first accepted release after the cutover.

6. Broader work plan

Step 5 is one foundation milestone. It does not by itself make Steady ready for clinical testing, payer review, or public availability. The broader program should run in the order below.

Phase	Theme	Work	Release boundary
Phase 1	Truth and workflow definition	Current versus target architecture, Steady Clinical workflow, user and role map, PHI data flow, data classification, and claims boundary.	Work starts now
Phase 2	Security foundation	Threat model, risk register, vendor and BAA register, tenant enforcement, identity, secrets, logging, incident response, backup, and recovery evidence.	Before supervised pilot
Phase 3	Permanent data spine	Postgres cutover, RLS active, Step 5 event-authoritative writes, provenance, corrections, retention, and replay operations.	Target Step 5 Sep 14 to 18
Parallel	BLS Part 6 validation	Continue the signed protocol, test plan, evidence collection, reviewer checkpoints, safety monitoring, and staged validation. Do not make it member-facing until its own gates pass.	Active throughout the build
Phase 4	Steady Clinical prototype	Caseload view, patient timeline, alerts, evidence-linked AI summaries, clinician feedback, review actions, audit history, and BLS oversight controls.	Synthetic clinician testing
Phase 5	Pilot readiness	Rescoped clinical configuration, consent, protocol, training, support, monitoring, security review, counsel review, BAA completion, and pilot acceptance evidence.	Before any real participant
Phase 6	Payer and enterprise testing	Organization administration, reporting, eligibility, population workflows, interoperability sandbox, and measurable pilot economics.	After pilot foundation
Phase 7	Public or consumer decision	Separate product posture, claims, support, safety monitoring, privacy, payments, accessibility, and release review.	Only after clinical and security review

7. Security and clinical deliverables

Security package	Clinical package
1. System context and trust boundaries 2. PHI data-flow diagram across six zones 3. Threat model and abuse cases 4. HIPAA security risk register 5. Vendor and subprocessor register 6. BAA status and data-access map 7. Identity, tenant, and privilege model 8. Logging and monitoring plan 9. Incident and breach-response update 10. Security-review handoff packet	1. Caseload and priority workflow 2. Patient timeline and evidence views 3. Alert severity and response ownership 4. AI summary with citations 5. Clinician approval, correction, and override 6. Feedback taxonomy 7. Escalation and re-entry workflow 8. Pilot inclusion and exclusion rules 9. Safety-monitoring responsibilities 10. BLS Part 6 validation and evidence packet 11. Rescoped clinical sign-off packet

These packages should describe both current controls and planned controls. Planned controls must carry an owner, target phase, and acceptance test. The public repository may hold public-safe architecture. Contracts, BAAs, security findings, account details, and reviewer reports need controlled storage.

8. Decisions and actions required from Travis

#	Decision	Required action
1	Near-term clinical scope	Confirm an adults-only, supervised, synthetic-first pilot with one organization and a limited care team.
2	BLS Part 6	Confirm it remains an active clinical validation workstream. Assign its reviewer, protocol owner, evidence owner, and validation schedule. Keep member-facing access gated until approval.
3	Reviewers	Name the clinical reviewers, healthcare and privacy counsel, and intended security reviewer.
4	Hosting direction	Choose the likely cloud or managed hosting direction and approve the initial Postgres, secret, backup, monitoring, and test-environment budget.
5	Data policy	Decide what may stay in the public repository and what must move to a private security and clinical workspace.
6	Vendor inventory	Provide the expected hosting, model, email, storage, monitoring, authentication, analytics, support, and billing vendors for the BAA register.
7	Repository governance	Set main as the default branch, protect it, require pull requests and green checks, and reconcile the older draft PR 10.

Immediate authorization requested

Approve the Step 5 target window and authorize the prerequisite work. No real patient data, payer data, or employee health data enters the system during this build period.

9. Documentation and repository corrections

Document or setting	Required correction
Root README	Separate current prototype, target platform, and release status. Stop leading external readers with the old consumer pricing thesis.
COMPLIANCE.md	Replace the wellness-only gate list with separate demo, clinical pilot, enterprise, and optional consumer tracks.
ADR 0010	Resolve whether Step 4 or Step 5 is the actual cutover. Define partial projections and the exact event-authoritative scope.
ADR 0007	Resolve the Accepted versus Proposed contradiction. Update the Postgres readiness statement for the new RLS transaction work.
ADR 0009	Record the status of counsel review and distinguish code exploration from the formal clinical-lane decision.
Security packet	Replace the wellness autonomous-engine packet with the platform threat model, PHI flow, tenant model, controls, risks, and evidence.
Investor materials	Retire or archive the old consumer-only deck so it is not circulated beside the platform narrative.
GitHub	Make main the protected default branch. Require CI. Close, update, or supersede the older draft PR 10.

10. Final direction

Steady should continue building. The event spine and tenancy work are the right long-term direction, and the test results show that the team can make difficult structural changes without breaking the prototype.

The next move is not to rush the final event cutover. First, make tenancy active in the target database, make RLS tests part of CI, define the authoritative event scope, make event and projection writes atomic, prove migration and rollback, and run the seven-day synthetic soak. BLS Part 6 continues beside this work under its separate clinical validation plan.

Under that plan, Step 5 executes during the September 14 to 18, 2026 window. The date is a target, while the ten go or no-go gates control the decision. That gives investors a credible engineering path, gives security reviewers evidence instead of promises, and keeps the system away from real clinical data until the proper reviews finish.

Step 5 answer

We will execute ADR 0010 Step 5 after the Postgres and tenant gates pass and after seven consecutive clean days in synthetic staging. The target cutover window is September 14 to 18, 2026.

Repository references

README: <https://github.com/tprawlings-lang/Emdr/blob/main/README.md>

ADR 0010: <https://github.com/tprawlings-lang/Emdr/blob/main/docs/adr/0010-event-sourced-longitudinal-spine.md>

ADR 0011: <https://github.com/tprawlings-lang/Emdr/blob/main/docs/adr/0011-tenancy-and-person-account-separation.md>

Data layer: <https://github.com/tprawlings-lang/Emdr/blob/main/src/lib/data.ts>

Projection code: <https://github.com/tprawlings-lang/Emdr/blob/main/src/lib/projections.ts>

Safety workflow: <https://github.com/tprawlings-lang/Emdr/blob/main/.github/workflows/safety.yml>

Current CI run: <https://github.com/tprawlings-lang/Emdr/actions/runs/33056802690>